

Administración de Redes y Seguridad

Unidad 1 - Conceptos de Seguridad



Unidad 1: Conceptos de Seguridad

Información, Seguridad, Privacidad, Confidencialidad, Integridad, Autenticidad, No repudio

Información

- ❖ ¿Qué se debe asegurar?
 - Los *activos* de la organización
 -
- ❖ ¿Qué lugar ocupa la información?
 - La *información* constituye un lugar muy importante en la organización ya que tiene un rol fundamental a la hora de cumplir sus objetivos



Información

- ❖ ¿Qué significa garantizar la **seguridad** de la información?
 - Significa proteger la información y los sistemas de información del acceso, uso, divulgación, interrupción, modificación o destrucción **no autorizadas**.

- ❖ ¿Qué significa garantizar la **privacidad** de la información?
 - Significa **no revelar** la información, o revelarla selectivamente, para protegerla de cualquier intromisión

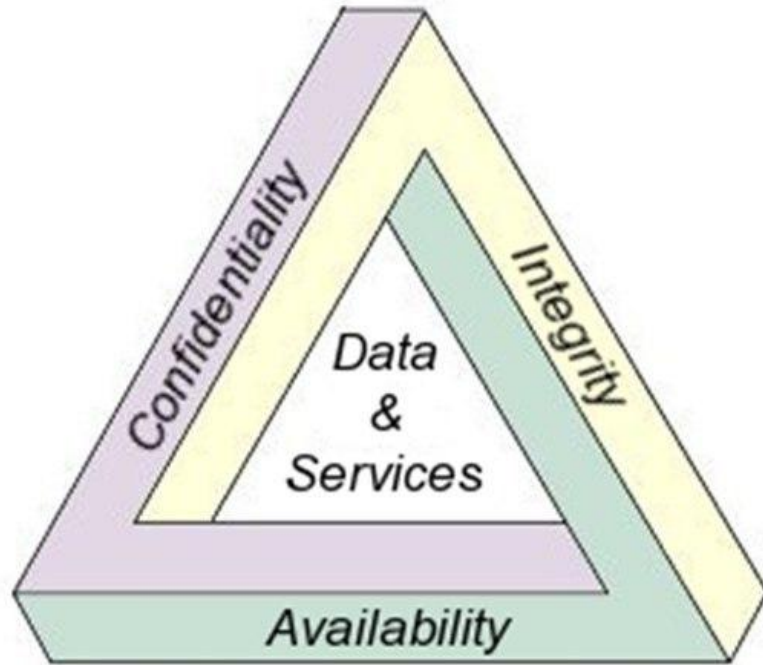


Desafío

- ❖ ¿Tenés un smartphone con android?
- ❖ ¿Te acordás donde estuviste hace un mes?
- ❖ Preguntale al servicio Location History de Google
- ❖ Otro ejemplo: ¿Por qué me vigilan si no soy nadie? | Marta Peirano | TEDxMadrid



Categorías de ataques



- ❖ **Interrupción**
 - Ataque a la **disponibilidad**
- ❖ **Intercepción**
 - Ataque a la **confidencialidad**
- ❖ **Modificación**
 - Ataque a la **integridad**
- ❖ **Fabricación**
 - Ataque a la **autenticidad**

Vulnerabilidades y Amenazas

- ❖ Una **vulnerabilidad** es una debilidad en un activo
- ❖ Una **amenaza** es una violación potencial de una vulnerabilidad



Tipos de Amenazas

❖ Naturales

- Incendios
- Terremotos
- Inundaciones

❖ Humanas

- Maliciosas
 - Internas
 - Externas
- No maliciosas
 - Impericia



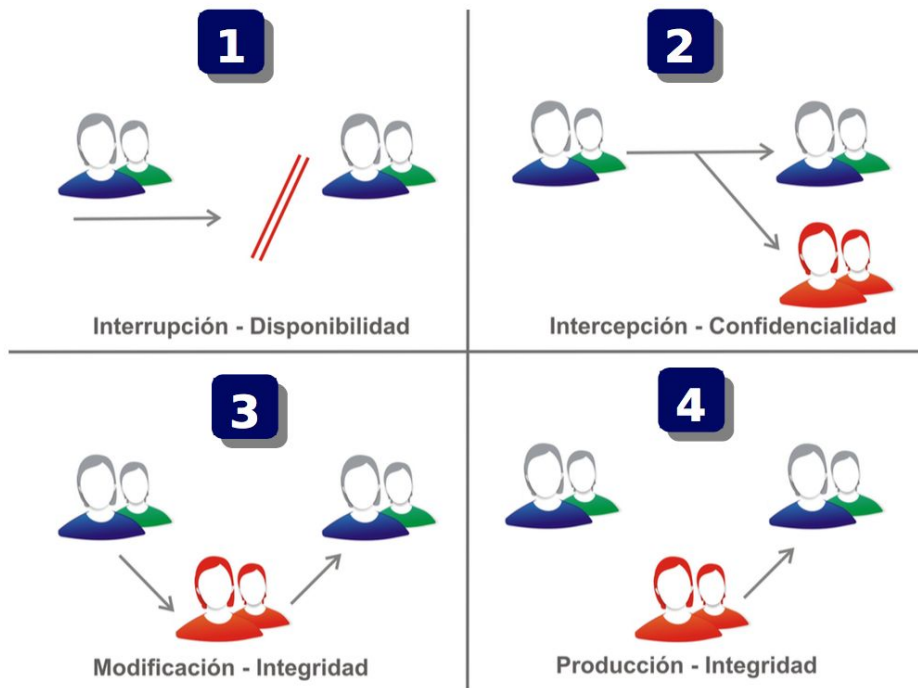
Incidente de Seguridad

Un ***incidente*** de seguridad es el evento adverso que afecta los activos de la organización

Todo incidente debe ser reportado a quien corresponda



Incidente de Seguridad



- ❖ **Interrupción**
 - Ataque a la **disponibilidad**
- ❖ **Intercepción**
 - Ataque a la **confidencialidad**
- ❖ **Modificación**
 - Ataque a la **integridad**
- ❖ **Fabricación**
 - Ataque a la **autenticidad**

Amenazas - Conceptos generales

- ❖ Las amenazas atentan contra:
 - La confidencialidad de la información
 - La integridad de la información
 - La disponibilidad de la información

- ❖ Son causadas por:
 - Fallas humanas
 - Ataques malintencionados
 - Catástrofes naturales



Amenazas - Conceptos generales

- ❖ La materialización de una amenaza puede causar
 - El acceso, robo modificación o eliminación no autorizadas de información
 - La interrupción de un servicio o el procesamiento de un sistema
 - Daños físicos o robo del equipamiento y medios de almacenamiento de información



Amenazas sobre las personas - Ingeniería Social

- ❖ La Ingeniería Social es un conjunto de trucos, engaños o artimañas que permiten confundir a una persona para que entregue información confidencial.
- ❖ **La principal defensa contra la ingeniería social es la concientización en la implementación de políticas de seguridad**



Amenazas sobre las personas - Ingeniería Social

❖ ¿Por qué funciona?

Según Kevin Mitnick, uno de los ingenieros sociales más famosos de los últimos tiempos, la ingeniería social se basa en estos cuatro principios:

- ❖ Todos queremos ayudar
- ❖ El primer movimiento es siempre de confianza hacia el otro
- ❖ No nos gusta decir “No”
- ❖ A todos nos gusta que nos alaben



Amenazas sobre las personas - Ingeniería Social

“La Seguridad muchas veces es una mera Ilusión. Una compañía puede tener la mejor tecnología, firewalls, sistemas de detección de intrusos, dispositivos de autenticación avanzados como tarjetas biométricas, etc y creen que están asegurados 100%. Viven una Ilusión. Sólo se necesita un llamado telefónico y listo. Ya son vulnerables a un ataque. La Seguridad no es un producto, es un Proceso”

Kevin Mitnik

Amenazas sobre las personas - Phishing y Pharming

- ❖ El **Phishing** es una combinación de ingeniería social y elementos técnicos para engañar a un usuario y lograr que éste entregue involuntariamente información confidencial a usuarios malintencionados. La forma más común es mediante el envío de mails falsos, escritos como si hubieran sido enviados por la auténtica organización.
- ❖ El **Pharming** consiste en alterar la asociación de nombre (www.mibanco.com) a dirección real (IP) para dirigir a un usuario a una dirección que no es la verdadera. Puede ser desconcertante ya que el usuario escribe por si mismo la dirección de la página web.

Amenazas sobre las personas - Spam

También llamado “Correo Basura”. Es uno de los principales medios para hacer llegar todo tipo de problemas a los usuarios del correo electrónico.

Se utiliza para:

- ❖ Publicidad no deseada
- ❖ Phishing (se vale de la ingeniería social)
- ❖ Transmisión de código malicioso

Amenazas sobre las personas - Hoax

Son mensajes de correo electrónico engañosos que se distribuyen en cadena. Algunos tienen textos alarmantes sobre catástrofes (virus informáticos, perder el trabajo o incluso la muerte) que puede suceder si no se reenvía el mensaje o se hace lo que el mismo indica. La motivación de un hoax es recolectar direcciones de correo y otros datos confidenciales

Amenazas en el control de acceso

Elementos del control de acceso:

- ❖ **Identificación:** es una secuencia de caracteres que identifica unívocamente al usuario: nombre de usuario.
- ❖ **Autenticación:** es la verificación que realiza el sistema sobre la identificación. Se puede realizar a través de:
 - Algo que se conoce: clave de acceso
 - Algo que se posee: tokens / tarjeta
 - Algo que se es: huella digital, iris, retina, voz
- ❖ **Autorización:** son los permisos asociados al usuario autenticado

Ataques de contraseñas

Consiste en la prueba metódica de contraseñas para lograr el acceso a un sistema, siempre y cuando la cuenta no presente control de intentos fallidos de logueo. Este tipo de ataque puede ser realizado:

- ❖ **Por diccionario:** existiendo un diccionario de palabras, una herramienta intentará acceder al sistema probando una a una las palabras incluidas en el mismo.
- ❖ **Por fuerza bruta:** una herramienta generará combinaciones de letras, números y símbolos formando posibles contraseñas y probando una a una en el login del sistema.

Ataques de contraseñas

Consiste en la prueba metódica de contraseñas para lograr el acceso a un sistema, siempre y cuando la cuenta no presente control de intentos fallidos de logueo. Este tipo de ataque puede ser realizado:

- ❖ **Por diccionario:** existiendo un diccionario de palabras, una herramienta intentará acceder al sistema probando una a una las palabras incluidas en el mismo.
- ❖ **Por fuerza bruta:** una herramienta generará combinaciones de letras, números y símbolos formando posibles contraseñas y probando una a una en el login del sistema.

Más ejemplos de amenazas

Acceso no autorizado a información sensible, como puede ser:

- ❖ Información confidencial impresa.
- ❖ Información confidencial guardada en medios de almacenamiento removibles (CDs, DVDs, pendrives).
- ❖ Información confidencial almacenada en notebooks.

Código Malicioso (Malware)

Virus/Gusanos/Troyanos/Spyware/Keyloggers:

- ❖ Destruyen datos
- ❖ Consumen recursos del equipo
- ❖ Permiten acceso de extraños al equipo
- ❖ Roban información (números de cuentas, claves, información financiera)
- ❖ Roban nuestra identidad

Los antivirus/ antispyware nos protegen del malware, pero no nos cubren de todos los riesgos, es por ello que debemos tomar precauciones.

Malware - ¿Cómo llega a nuestro equipo?

Sin nuestro consentimiento:

- ❖ Navegando por sitios de Internet que descargan su código malicioso en navegadores mal configurados y/o desactualizados.

Con nuestro consentimiento:

- ❖ Instalando algún Freeware (programa gratuito). Al aceptar sus condiciones de uso (generalmente en inglés y que nunca se leen) comienzan a funcionar como espías.
- ❖ Siendo víctimas de Ingeniería social

Buenas Prácticas

Como administradores/desarrolladores:

- ❖ Siguiendo las buenas prácticas de seguridad que indican los estándares / normas nacionales e internacionales.
- ❖ Aprobando la materia :D

Concientización

Un **programa de concientización de Seguridad** resulta fundamental para fortalecer los eslabones más débiles de la cadena de seguridad, las personas por:

- ❖ Desconocimiento de las amenazas.
- ❖ Desconocimiento de las medidas de seguridad
- ❖ Desconocimiento de los roles y responsabilidades de cada persona, con respecto a la seguridad

Este programa debe estar dirigido a todo el personal que trabaje con información de la organización.

Concientización

El programa de concientización debe incluir:

- ❖ Acciones de impacto, como ser:
 - Sesiones de concientización para los directivos
 - Sesiones de concientización para personal de TI
 - Sesiones de concientización para usuarios finales

- ❖ Acciones de seguimiento, como ser:
 - Eventos de seguridad
 - Boletines Internos
 - Posters
 - Tips para la navegación

Concientización

El programa de concientización debe ser realizado a medida, teniendo en cuenta perfil de la empresa, tareas que se realizan y rasgos del personal.

Las actividades/ejemplos deben relacionarse con las actividades diarias del personal.

Fin Unidad 1